

(주)해랑금융 위탁사 점검 결과 보고서

수탁사 (피감사)	(주)해랑금융
위탁사 (감사 주체)	(주)하랑항공
위탁 업무 범위	항공 마일리지 연계 결제 API 중계, 결제 데이터 수신·저장·정산, 카드사 연동 토큰화 처리
점검 기간	2026년 01월 26일 ~ 2026년 02월 13일
보고서 작성일	2026년 03월 09일

본 보고서는 (주)하랑항공이 위탁한 마일리지 연계 결제 API 중계 및 금융 데이터 처리·정산 업무 수행과 관련하여 (주)해랑금융의 개인정보 보호 관리 수준을 점검한 결과를 기술한 문서입니다.

개정 이력

버전	변경일	변경 사유	변경 내용	작성자	비고
1.0	2026-02-16	최초 작성	결과 보고서 초안 작성	(주)리베로	
1.1	2026-02-18	내용 수정	2.1 진단 결과 변경	(주)리베로	
1.2	2026-03-09	내용 수정	증적 자료 수정	(주)리베로	

목차

1. 진단 결과 요약	4
1.1 보안 준수율 분류 기준	4
1.2 종합 등급	4
1.3 범주별 등급	5
1.4 핵심 위험 사항 (즉시 조치 필요)	6
2. 범주별 상세 점검 현황	7
2.1 내부 관리 계획 및 조직	7
2.2 접근 통제 및 권한 관리	8
2.3 접속기록 보관 및 점검	8
2.4 비밀번호 관리	8
2.5 접속 보안 및 네트워크	9
2.6 단말기 보안	9
2.7 개인정보 암호화 및 출력 통제	9
2.8 개인정보 생명주기	10
3. 증적자료 목록 및 첨부	11
4. 결론 및 향후 조치 계획	21

1. 진단 결과 요약

1.1 보안 준수율 분류 기준

분류	양호(Y)	부분양호(P)	취약(N)
점수	1	0.7	0

총점	100 ~ 90	89 ~ 70	69 ~ 50	49 ~ 0
등급	A	B	C	D

- 각 점검항목을 양호, 부분양호, 취약으로 평가하여 분류한다.
- 총점은 53개의 점검항목 점수의 합산을 100점 만점으로 환산한 값이다.
$$\text{환산 점수} = \frac{(\text{양호 개수}) \times 1 + (\text{부분양호 개수}) \times 0.7 + (\text{취약 개수}) \times 0}{\text{점검 항목 수}} \times 100$$
- 환산 점수에 따라 90점 이상은 A, 70점 이상 90점 미만은 B, 50점 이상 70점 미만은 C, 50점 미만은 D로 등급을 산정한다.

1.2 종합 등급

종합 등급	양호	부분양호	취약
B	32건	11건	10건

- 점검결과 취약 10건, 부분양호 11건을 포함하여 총 21건에 대한 개선 조치가 필요하다.
- 반복 지적 사항(운영 DB 과잉 접근 권한, 보안서약서 미징구, 결제 이력 DB 자동 배치 오류)은 최우선 과제로 지정한다.

1.3 범주별 등급

점검 영역	등급	주요 취약 사항
내부 관리 계획 및 조직	B	보안서약서 미징구, (주)하랑항공 비상연락망 미등재
접근 통제 및 권한 관리	B	운영 DB 차등권한 미적용, 외주 계정 잔류
접속기록 보관 및 점검	A	SIEM 임계치 미문서화, 월간 검토보고서 미작성
비밀번호 관리	B	비밀번호 유효기간 미설정
접속 보안 및 네트워크	B	SSL 검사 미적용, HTTPS 우회 클라우드 업로드 차단 불가
단말기 보안	B	NAS 공유폴더 내 파일 12건 평문 저장
개인정보 암호화 및 출력 통제	B	결제 이력 관련 출력물 관리대장 미기재, 출력물 프린터 트레이 방치
개인정보 생명주기	D	재위탁 서면승인 미비, 개인정보 파일 반출입 관리대장 누락, 결제이력 DB 내 보유기간 초과 2,341건 미파기, 위탁사에 개인정보 파기보고 누락

1.4 핵심 위험 사항 (즉시 조치 필요)

- 신규 입사자·퇴사자·외주·파견 인력 **보안서약서 미징구** - 정보 유출 발생 시 책임 귀속 불명확
- **운영 결제 DB 차등권한 미적용** - API 개발팀 5명 중 3명이 운영 DB 직접 접근 가능, 사용자 권한 적절성 검토 미실시
- 레거시 모니터링 콘솔 **비밀번호 유효기간 미설정**, 최장 14개월 미변경 계정 2건 확인. 일부 시스템 **임시 비밀번호 강제 변경 미적용**
- 주요 서버(API·결제 DB) 월 1회 정기 패치 양호. SFTP 서버 마지막 **OS 패치 5개월 경과, CVE 취약점 3건 미패치** - 담당자 재부팅 우려로 지연
- NAS '결제정산_2025' 폴더 전체 임직원 읽기 권한 부여 상태, 해당 폴더 내 **결제이력 파일 12건 평문 저장** - 내부 유출 경로 상시 노출
- WSUS 연동 자동 패치 배포 운영 중이나, **패치 미적용 단말 2건 확인** - 예외 처리 문서는 존재하나 **승인이 완료된 상태로 운영 중**이며 네트워크 격리 등 대체 통제 미적용
- **침해사고 대응절차 미흡** - (주)하랑항공 담당자 비상연락망 미등재, API Key 유출 시나리오 전용 절차 없음, 모의훈련 전무
- 마일리지 정산 배치 재위탁(주)한길 회계법인) 시 (주)하랑항공 서면 승인 없이 구두 진행, **재위탁 계약서 내 개인정보보호 조항 미포함**
- 결제이력 자동 삭제 배치 **3개월 오류 방치** - 보유기간(90일) 초과 2,341건 미파기
- 개인정보 파기 결과 (주)하랑항공 **보고 절차 미수립**. CPO 내부 보고도 분기 1회에 그침

2. 범주별 상세 점검 현황

2.1 내부 관리 계획 및 조직

- 개인정보보호 내부관리계획서(v3.1, 2025.01) 대표이사 결재 완료, 사내 그룹웨어에 최신본 게시. PCI-DSS·전자금융거래법 연계 항목 포함, 연 1회 정기 검토·갱신 이력 확인
- 내부관리계획서 전 직원 이메일 및 그룹웨어 공표 실시하고 있으나, 직원 구두 질의 시 핵심 내용(암호화 기준·사고 보고 절차) 답변 미흡 사례 다수 확인
- 위탁사(㈜하랑항공) 담당자 비상연락망 미등재, API Key 유출 시나리오 전용 대응절차 부재, (주)하랑항공 통보 SLA(4시간) 미명시, 모의훈련 미실시
- 재해·재난 대응 메뉴얼 및 BCP 완비. 결제 DB 서버 이중화 및 오프사이트 백업 구성, 분기 1회 복구 테스트 실시 확인
- CISO 지정 문서 및 내부관리계획서 내 성명·직책 명시 확인, 정보보호법 제13조상 법적 자격 요건(학위·경력) 충족 확인
- 개인정보취급자 명단 HR 시스템과 월 단위 대조, 취급자 최소화 원칙 준수. 파견·외주 인력 포함 최신 관리 확인
- 신규 입사자·퇴사자·외주·파견 인력 보안서약서 미징구 - 즉각 징구 및 권한 재검토 필요
- 전체·신규 입사자·직무별 연 2회 개인정보보호 교육 실시, 이수율 100%. 금융 업무 특화 교육 포함, 온라인 퀴즈를 통한 효과 측정 운영 확인
- 건물·사무실 카드키+생체인식(지문) 이중 통제, CCTV 전 구역 커버, 비인가자 방문 시 에스코트 절차 운영
- 서버실 카드키+지문 별도 이중 통제, 출입 로그 최근 1개월 정상 유지, 결제 DB 서버 별도 물리적 보호 확인
- 개인정보 포함 출력물 관련 물리적 보안 설비는 구비되어 있으나, 관리대장 기재 누락 및 출력물 방치 사례가 확인되어 실효성 미흡

2.2 접근 통제 및 권한 관리

- API Gateway 계정 목록에 6개월 전 퇴직한 외주 인력 계정 1건 잔류. 개인정보취급자 명단 미등재된 계정 존재 여부 확인
- **API 개발팀 5명 중 3명이 운영 결제 DB 직접 접근 권한 보유 — 개발 환경 권한이 운영 DB에 그대로 적용된 권한 크립트 상태. 사용자 권한 적절성 검토 미 실시**
- ITSM 기반 4단계 승인 워크플로우(신청→팀장 승인→정보보호팀 검토→IT 발급) 운영. 승인 없는 직접 계정 발급 기술적 차단 확인, 승인 이력 3년 보관 확인
- 퇴사자 1명 HR 시스템 연동 오류로 퇴사 후 4일 경과 후 계정 말소. 부서이동 후 3개월 경과 직원 1명의 구 부서 결제 DB 조회 권한 미회수 상태
- 계정·권한 부여·변경·삭제 이력 AWS S3 (Object Lock, 3년 보유) WORM 보관, 위변조 방지 적용 확인
- 결제 DB-API Gateway-SFTP 서버 모두 1인 1계정 원칙 준수. 배치 처리용 서비스 계정은 시스템 전용 분리, 개인 로그인 불가 구조 확인
- 세션 타임아웃 결제 DB 콘솔 15분-API Gateway 콘솔 10분 적용, 타임아웃 후 MFA 재인증 구조 전사 강제 적용
- 결제 DB 콘솔-API Gateway 5회 로그인 실패 시 계정 15분 잠금, 잠금 해제 시 본인 확인 절차 완비. 로그인 실패 이벤트 SIEM 연동 확인

2.3 접속기록 보관 및 점검

- 개인정보처리시스템 접속기록 법령 요구 6개 항목(식별자·접속일시·접속지 IP·처리 정보주체·수행업무·조회건수) 완전 기록. API 호출 로그에 엔드포인트·처리 건수·응답코드 추가 포함
- SIEM 기반 실시간 이상탐지 운영 중이나 임계치 기준 내부 규정 미명시, 담당자 경험 기반 운영. 최근 3개월 이상탐지 이벤트 로그 존재하나 검토·처리 결과 보고서 미작성, 월 1회 정기 검토 보고서 미작성
- API 호출 로그·결제 DB 접속기록 2년 이상 보관, 고유식별정보 처리 기준 의무 충족. 실제 2년 전 로그 정상 조회 확인
- WORM 스토리지(AWS S3 Object Lock, 컴플라이언스 모드, 2년 보유)에 접속 로그 서버 데이터 자동 저장. 관리자 계정으로 기록 수정·삭제 기술적 차단 확인, 해시값 무결성 검증 일별 수행 확인

2.4 비밀번호 관리

- 개인정보처리시스템 비밀번호 정책(복잡도·길이·유효기간) 설정 확인. 결제 DB 콘솔-API Gateway 콘솔 비밀번호 설정 법령 기준 충족 확인. 레거시 내부 시스템 비밀번호 유효기간 미설정, 최장 14개월 비밀번호 미변경 계정 2건 확인. 일부 시스템 임시 비밀번호 발급 후 강제 변경 미적용
- 개인정보취급자 PC·노트북 화면보호기 및 로그인 비밀번호 설정 완료. Active Directory의 GPO 화면보호기 10분·비밀번호 잠금 GPO 전사 적용 확인. MDM 확인 단말기 전체 준수 확인. 재택근무·외부 접속 단말 전체 GPO 전사 강제 적용

2.5 접속 보안 및 네트워크

- 외부 접속 시 IPsec VPN + OTP(TOTP) MFA 강제 적용. (주)하랑항공 연동 구간 전용선 mTLS + TLS 1.3 전용 채널 사용, 방화벽 직접 접근 차단 확인
- 방화벽·IDS/IPS 설치 완비. DMZ(API Gateway·SFTP)와 내부 결제 DB 별도 방화벽 구분, 분기 1회 정책 검토 운영
- 논리적 망분리 완전 적용, 예외 구간 없음 확인됨. 분기 1회 방화벽 정책 검토 이력 확보
- **URL 필터링(카테고리 기반) 및 비인가 프로그램 설치 차단 정책 미적용 및 SSL 검사 미적용으로 HTTPS 경유 개인 클라우드(Google Drive 등) 접속 탐지·차단 불가 - 테스트 시 차단 없이 업로드 성공 확인**
- 무선랜 WPA3 + WIPS 적용. 업무용·게스트 VLAN 완전 분리, 비인가 AP 탐지·차단 이력 확인

2.6 단말기 보안

- 2025년 10월 외부 전문업체 취약점 점검 실시, High 2건 발견 후 30일 이내 전건 조치 완료, 재점검 통과 확인
- 전 서버(API·결제 DB·SFTP) 백신 설치, 자동 업데이트·실시간 감시 활성화. 중앙 관리 콘솔 모니터링 운영
- 주요 서버(API·결제 DB) 월 1회 정기 패치 적용 양호. SFTP 서버는 마지막 OS 보안패치 5개월 경과, CVE 취약점 3건 미패치, 담당자 재부팅 우려로 지연 중.
- **NAS '결제정산_2025' 폴더에 전체 임직원 읽기 권한 부여, 결제이력 파일 12건 평문 저장 상태. 접근 제한·암호화·로깅 미조치**
- 전 단말 백신 설치, MDM 컴플라이언스 기준 미준수 0건. 자동 업데이트·실시간 모니터링 활성화 확인
- WSUS 자동 패치 배포 운영 중. 패치 미적용 단말 2건에 대한 네트워크 격리 등 대체 통제 미적용 상태
- GPO로 전 단말 USB 포트 쓰기 차단. 승인된 암호화 USB 예외 허용, 최근 1개월 무단 연결 시도 3건 탐지·차단 확인

2.7 개인정보 암호화 및 출력 통제

- 사용자 비밀번호 bcrypt 적용, MD5-SHA-1 등 취약 알고리즘 미사용. 전 시스템 동일 기준 적용
- 카드번호 PCI-DSS 기준 토큰화(원번호 미보관), 계좌번호·결제이력 AES-256+HSM 암호화 저장 확인
- API·SFTP 주요 구간 mTLS+TLS 1.3 / PGP 암호화 적용. 단, 관리자 PC ↔ 결제 DB 콘솔 접속 구간 일부 HTTP 비암호화 통신 확인
- 전 업무용 단말 BitLocker 디스크 암호화 적용, MDM 미적용 단말 0건 확인
- 암호화 키 관리 절차서 완비, HSM 기반 키 관리. Primary/Backup 2인 담당 체계, 연 1회 키 로테이션 이력 확인
- 계좌번호·카드번호·결제이력 조회 화면 마스킹 적용(계좌 뒤 4자리 외, 카드 중간 8자리 마스킹). JIT 팀장 승인 후 30분 임시 해제, 엑셀 다운로드 시 마스킹 유지 확인

- 결제 이력 관련 출력물 발생 건 중 관리대장 미기재 항목 확인 및 점검 당일 결제 승인 내역 출력물 프린터 트레이 방치 확인. 출력 DLP 미적용, 보안 출력 솔루션 미도입 상태

2.8 개인정보 생명주기

- 위탁계약 범위 내 최소 수집 원칙 준수. DB 스키마 대조 결과 계약서 범위 초과 항목 수집 없음 확인
- (주)하랑항공 전용 DB 스키마 분리 운영. 위탁 개인정보 식별 및 분리 체계는 기술적으로 적용되어 있으나 접근통제 레이블 미비 확인
- 마일리지 정산 배치 업무를 (주)한길 회계법인에 재위탁하면서 (주)하랑항공의 서면 승인 없이 구두로만 진행, 재위탁 계약서 내 개인정보보호 조항 미포함
- 개인정보 파일 반출입 관리대장 기재 부분 누락 확인. 반출 승인 절차 미승인 이메일 발송 사례 확인
- 전자파일 완전삭제 정책(복구 불가 방식) 수립·적용 확인
- 결제이력 DB 자동 삭제 배치(90일 보관 정책)가 스키마 변경으로 3개월간 오류 상태 방치 - 보유기간 초과 데이터 2,341건 미파기 상태
- 종이 문서 세절 파기 절차 일부 시행 중이나 파기 대장 기재 현황 미흡
- 전자금융거래법(5년)·신용정보법 기준 보관 대상 분리 DB 운영 확인
- 개인정보 파기 결과를 위탁사(주)하랑항공)에 보고하는 절차 미수립. CPO 내부 보고도 분기 1회에 그쳐 월 1회 이상 보고 체계 수립 필요

3. 증적자료 목록 및 첨부

본 진단 결과보고서에 첨부되는 증적자료 목록입니다. 각 자료는 점검 기간(2026.01.26~02.13) 중 수집·확인된 원본 또는 사본입니다.

No.	분류	증적자료명	형태	수집일	확인자
1	접속 기록	결제 DB-API Gateway 접속기록 화면	화면 캡처본	2026.01.26	김선아
2	접속 기록	WORM 스토리지 설정 화면	화면 캡처본	2026.01.26	김선아
3	암호화	DB 암호화 정책서	문서 사본	2026.02.03	오설
4	암호화	암호화 키 관리대장 (HSM/KMS 포함)	문서 사본	2026.02.05	오설
5	재위탁	개인정보처리업무 재위탁 계약서	문서 사본	2026.02.10	오설
6	재위탁	(주)하랑항공 서면승인 부재확인서	문서 사본	2026.02.08	오설
7	파기	개인정보 파기절차 점검보고서	문서 사본	2026.01.30	김선아
8	파기	전자금융거래법·신용정보법 기준 분리 보관 DB 현황	화면 캡처본	2026.02.02	김선아
9	파기	분리 보관 DB 접근권한 설정 내역	화면 캡처본	2026.02.07	김선아

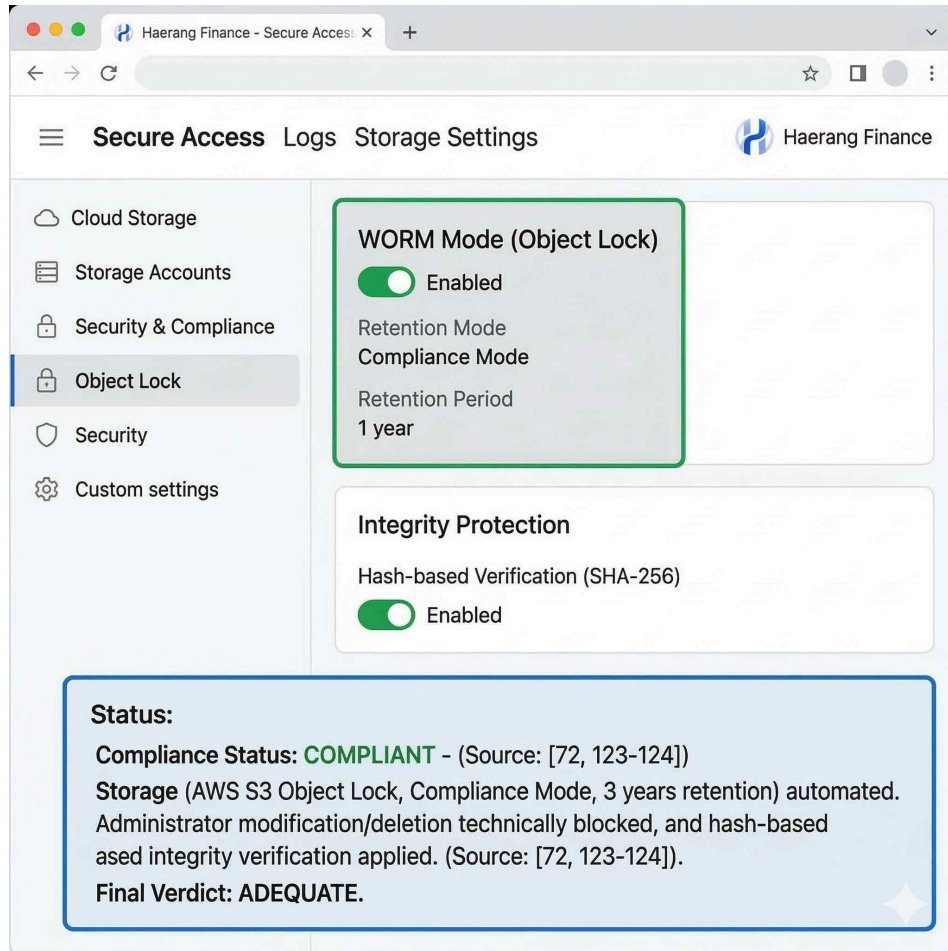
※ 위 목록에 포함되지 않은 추가 증적자료는 별도 협의 후 제출합니다.

※ 각 증적자료 원본은 (주)하랑항공 보안컨설팅팀이 보관하며, 수탁사 요청 시 열람 가능합니다.

[증적자료 실물 첨부 공간]

증적 1

[illegible]



DB 암호화 정책서

1. 목적 및 적용 범위

목적	개인정보 및 금융거래 데이터를 안전한 암호화 알고리즘으로 보호하여 개인정보보호법·전자금융거래법·PCI-DSS 요건을 충족함
적용 범위	결제 DB / API Gateway / SFTP 서버 / 내부 NAS에 저장되는 모든 개인정보 및 금융거래 데이터
적용 법령	개인정보보호법 제23-24-29조, 안전성 확보조치 기준 제7조, 전자금융거래법 제22조, PCI-DSS Req.3-4
문서 소유자	정보보호팀장 (CPO 승인)
검토 주기	연 1회 이상 (관련 법령 개정 시 즉시 검토)

2. 암호화 대상 및 적용 알고리즘

구분	데이터 항목	암호화 방식	알고리즘	키 길이	적용 시스템
고유식별정보	카드번호	토큰화(PCI-DSS)	PCI-DSS Tokenization	N/A	결제 DB
고유식별정보	계좌번호	대칭키 암호화	AES-256-GCM	256bit	결제 DB
개인정보	성명·연락처	대칭키 암호화	AES-256-CBC	256bit	결제 DB / API GW
인증정보	사용자 비밀번호	일방향 해시	bcrypt (cost 12)	N/A	전 시스템
전송 데이터	API 연동 구간	전송 암호화	TLS 1.3 / mTLS	256bit	API Gateway
전송 데이터	SFTP 파일 전송	파일 암호화	PGP + TLS	4096bit	SFTP 서버

※ 취약 알고리즘(MD5, SHA-1, DES, 3DES, RC4)은 전면 사용 금지. 분기 1회 적용 현황 점검 필수.

암호화 키 관리대장 (HSM / KMS 포함)

점검항목: 2.6.5 (암호화 키 관리) | PCI-DSS Req.3.6 - 전자금융거래법 제22조 - 개인정보보호법 시행령 제30조

수탁사	(주)해랑금융
위탁사	하랑항공
문서번호	HARANG-SEC-2025-062
작성일	2025년 06월
작성자	김민지 (서명)
승인자	정민준 (서명)
문서버전	v1.0

▶ 점검 확인 항목 요약 (2.6.5)		
확인 ①	암호화 키 관리 대장 보유 여부	✓ 확인
확인 ②	키 생성·보관·로테이션·폐기 절차 문서화	✓ 키 관리 절차서 확인 / HSM+AWS KMS 이중 적용
확인 ③	키 담당자 1인 의존 여부	✓ Primary(정보보호팀장) / Backup(정보보호팀 선임) 2인 지정
확인 ④	연 1회 키 로테이션 실시 여부	✓ 로테이션 이력 확인 / 예정 일정 수립 완료

※ 본 문서는 PCI-DSS Req.3, 전자금융거래법 제22조, 개인정보보호법 시행령 제30조에 따른 금융 수탁사 전용 암호화 증적자료입니다. 외부 공개 금지.

2. 현재 운영 중인 키 목록								
No	키 식별자 (Key ID)	용도	알고리즘	생성일	만료일	보관 위치	담당자	상태
001	HARANG-AES-001	계좌번호 암호화	AES-256-GCM	2025.01.02	2026.01.01	AWS KMS	홍○○	활성
002	HARANG-AES-002	개인정보 암호화	AES-256-CBC	2025.01.02	2026.01.01	HSM	홍○○	활성
003	HARANG-PGP-001	SFTP 파일 암호화	PGP RSA-4096	2025.01.02	2026.01.01	HSM	김○○	활성
004	HARANG-AES-000	계좌번호 암호화	AES-256-GCM	2024.01.02	2025.01.01	AWS KMS	홍○○	만료

※ 만료된 키는 HSM 내 폐기 처리 후 '4. 키 이력' 시트 폐기 대장에 기록해야 합니다.

3. 키 생성·변경·폐기 이력							
No	일시	키 식별자	처리 유형	처리 사유	처리자	승인자	비고
001	2025.01.02	HARANG-AES-001	생성	신규 암호화 정책 적용	홍○○	정보보호팀장	
002	2025.01.02	HARANG-AES-002	생성	신규 암호화 정책 적용	홍○○	정보보호팀장	
003	2025.01.02	HARANG-PGP-001	생성	SFTP 파일 암호화 도입	김○○	정보보호팀장	
004	2025.01.03	HARANG-AES-000	폐기	키 로테이션 (만료)	홍○○	정보보호팀장	HSM 내 완전 삭제

개 인 정 보 처 리 업 무

재 위 탁 계 약 서

개인정보보호법 제26조 제1항·제6항, 제29조 / 동법 시행령 제28조 제1항

※ 위탁사(하랑항공) 사전 승인 필요 — 본 계약은 하랑항공의 승인 후 효력 발생

원 위 탁 사	하랑항공
재위탁사 (갑)	(주)해랑금융
재수탁사 (을)	한길 회계법인
재위탁 업무	마일리지 정산 배치 처리
계약 문서번호	HARANG-RETRUST-2025-001
계 약 일	2025년 03월 01일
계 약 기 간	2025년 03월 01일 ~ 2027년 02월 28일

본 계약서는 개인정보보호법 제26조 및 동법 시행령 제28조 제1항에 따라 작성된 공식 재위탁 계약서입니다.

재위탁 사전 서면 승인 부재 확인서

개인정보보호법 제26조 제1항 위반 근거 문서

본 확인서는 (주)해랑금융이 한길 회계법인에 개인정보 처리업무를 재위탁함에 있어, 위탁사(하랑항공)의 사전 서면 승인 문서가 존재하지 않음을 점검자(하랑항공)와 피점검자(해랑금융) 쌍방이 확인하는 공식 증적 문서입니다.

1. 확인 대상

점 검 기 관	하랑항공 (위탁사)
피점검 기관	(주)해랑금융 (수탁사)
재 수 탁 사	한길 회계법인
재위탁 업무	마일리지 정산 배치 처리 (월별 정산 데이터 집계·검증·보고서 생성)
점 검 일	2026년 02월 08일
관 련 법 령	개인정보보호법 제26조 제1항, 동법 시행령 제28조 제1항
판 정 결 과	【 취약 】 — 위탁사 사전 서면 승인 요건 미충족

2. 부재 확인 경위

순 서	확인 방법	확인 내용
①	서류 목록 요청	점검자가 재위탁 관련 전체 증적 제출을 요청함. (재위탁 계약서, 하랑항공 서면 승인 문서 포함)

개인정보 파기 절차 점검 보고서

결제이력 보유기간 초과 데이터 미파기 취약 사항 점검 결과

점검 일시	2026년 01월 30일
점검 항목	개인정보 보유기간 준수 및 파기 절차 이행 여부
점검 대상	결제이력 테이블 (TB_PAYMENT_HIST) — prod-db-01
점검 담당자	정보보호팀 박은빈
판정 결과	[취약]

본 문서는 개인정보보호법 제21조에 근거한 파기 의무 점검 결과 보고서입니다.

Haerang Finance - Separated Data Storage DB Overview

Search... Last 24 hours

Data Separation Status (by Regulation)

DB Name	Regulation	Data Type	Retention Period (Years)	Storage Type	Status
Payment Auth History DB	Electronic Financial Transactions Act	Credit/Mileage Payment	5	WORM (S3 Object Lock)	Active
Credit Information DB (Active)	Credit Information Use Act	Personal Identification	N/A	Standard RDS	Active
Credit Information DB (Archive)	Credit Information Use Act	Expired Records	3-5	Cold Storage S3	Archived

감사 확인: 준수 - (출처: [146])
 전자금융거래법(5년 보관)에 따른 분리된 '결제 승인 이력 DB' 운영.
 기간 만료 데이터의 자동 아카이빙 처리. (출처: [146]).
 / Audit Check: COMPLIANT - (Source: [146]) Operation of
 separated 'Payment Auth History DB' according to
 Electronic Financial Transactions Act (5-year retention).
 Automated archiving of expired data. (Source: [146]).

Haerang Finance - Separated DB Access Control Policy

Payment Auth History DB Access Control

Access Policy (RBAC)

Payment Auth DB Admin Role → Grant Full Access

Payment Auth DB Analyst Role → Grant Read Access

MFA Requirement ☒ Enabled

Access Restrictions (IP/Region) ☒ Enabled

Users Name	Payment Auth DB
Payment Auth DB	Payment Auth DB
Payment Auth DB	Payment Auth DB

Access Restrictions (IP/Region)

Allowed IPs	Regions
10.110.120.20	-
10.188.152.250	Allowed
10.110.15.233	-

Automated Purge Settings ☒ Enabled

Purge data older than 5 years

Schedule: Monday, 16:03:00

Log: Enabled

감사 확인: 준수 - (출처: [3, 4, 142])
법령 요구 6개 항목 기준 접근 제한. 미승인 접근의 기술적 차단.
보관 기간 초과 데이터의 자동 파기 확인. (출처: [3, 4, 142]).
/ Audit Check: COMPLIANT - (Source: [3, 4, 142]) Restricted access based on legal requirement 6 items. Technical blocking of unapproved access. Verified automated purge of data exceeding retention period. (Source: [3, 4, 142]).

4. 결론 및 향후 조치 계획

(주)해랑금융은 (주)하랑항공으로부터 위탁받은 마일리지 연계 결제 API 중계 및 금융 데이터 처리·정산 업무 수행에 있어 일부 기술적·관리적 보호조치가 구축되어 있습니다. 그러나, 보안서약서 미징구, 운영 DB 차등권한 미적용, NAS 공유폴더 결제이력 평문 저장, 보유기간 초과 2,341건 미파기, 재위탁 서면 승인 미비 등의 개인정보보호법 위반 소지가 있는 중대 취약점이 다수 확인되었습니다. 특히 결제이력 자동 파기 배치 오류가 3개월간 방치된 점, 그리고 (주)하랑항공 위탁 데이터에 대한 파기 결과 보고 절차가 전혀 수립되어 있지 않은 점은 실제 침해 사고 발생 시 위탁사인 (주)하랑항공의 법적 책임으로 이어질 수 있어 조속한 개선이 요구됩니다.

향후 조치 일정

구분	일정	내용
조치 계획서 제출	2026년 04월 29일까지	(주)해랑금융 → (주)하랑항공 제출
긴급 항목 조치	2026년 05월 12일까지	보안서약서 징구·DB 접근권한 축소·NAS 암호화 이행 결과 보고
단기 항목 조치	2026년 07월 12일까지	출력물 DLP·반출입관리·파기배치 등 이행 결과 보고
중기 항목 조치	2026년 10월 12일까지	재위탁계약·SSL 검사·위탁사SLA 이행 결과 보고
재점검	2026년 11월 중	(주)하랑항공 현장 재점검 실시

각 자료는 점검 기간(2026.01.26~02.13) 중 수집·확인된 원본 또는 사본입니다.

본 보고서는 대외비이며 수신자 외 무단 배포 및 공개를 금합니다.

작 성	검 토
소속 : (주)리베로 보안컨설팅팀	소속 : (주)하랑항공 개인정보보호팀장
성명 : 최 호 준 (서명)	성명 : 김 희 민 (서명)
일자 : 2026년 03월 13일	일자 : 2026년 03월 13일